

# **PROJET DE SECURISATION D'UN SI / FICHIER DAT**

## Table des matières

|                                                   |    |
|---------------------------------------------------|----|
| 1. Présentation du prestataire .....              | 3  |
| 1.1 Qui sommes-nous ? .....                       | 3  |
| 1.2 Contexte de la mission.....                   | 3  |
| 1.3 Objet de notre intervention.....              | 3  |
| 2. Analyse de l'existant.....                     | 4  |
| 2.1 Objectif de l'analyse .....                   | 4  |
| 2.2 État des lieux du système d'information ..... | 4  |
| 2.3 Analyse des vulnérabilités .....              | 5  |
| 2.4 Synthèse des risques .....                    | 6  |
| 3. Architecture cible proposée.....               | 6  |
| 3.1 Objectifs de l'architecture .....             | 6  |
| 3.2 Schéma AVANT / APRÈS .....                    | 7  |
| 3.3 Description de l'architecture cible .....     | 8  |
| 4. Choix techniques et benchmarking .....         | 9  |
| 4.1 Pare-feu .....                                | 9  |
| 4.2 Supervision .....                             | 10 |
| 4.3 SIEM .....                                    | 10 |
| 4.4 Serveur de fichiers .....                     | 10 |
| 4.5 Solution de sauvegarde .....                  | 10 |
| 4.6 IDS/IPS .....                                 | 11 |
| 5. Politique de sécurité technique.....           | 12 |
| 5.1 Principes appliqués .....                     | 12 |
| 5.2 Mesures techniques de sécurité .....          | 13 |
| 5.3 Synthèse opérationnelle .....                 | 14 |
| 6. Partie technique .....                         | 14 |
| 6.1. Matrice de flux.....                         | 14 |
| 6.2. IDS/IPS .....                                | 17 |
| 6.3 Proxy / Filtrage web — SquidGuard.....        | 17 |
| 7. RACI .....                                     | 17 |
| 8. Planning.....                                  | 19 |
| 9. Conclusion.....                                | 19 |

# 1. Présentation du prestataire

## 1.1 Qui sommes-nous ?

Nous sommes une équipe de six consultants spécialisés en cybersécurité et architecture des systèmes d'information.

Nos compétences couvrent l'audit de systèmes d'information, la conception d'architectures réseau sécurisées, la gestion des identités et des accès, ainsi que la mise en conformité réglementaire (RGS, RGPD, référentiels ANSSI). Nous intervenons en tant que prestataire externe mandaté pour accompagner l'hôpital dans la refonte complète de son système d'information.

## 1.2 Contexte de la mission

L'établissement hospitalier auprès duquel nous intervenons est reconnu comme Opérateur d'Importance Vitale (OIV) au sens de la loi de programmation militaire (LPM). À ce titre, il est soumis à des exigences strictes en matière de disponibilité, d'intégrité et de confidentialité de son système d'information, notamment vis-à-vis des référentiels de l'ANSSI.

Dans ce contexte, l'hôpital a sollicité notre équipe afin de procéder à un audit complet de l'architecture technique existante et de proposer une nouvelle architecture sécurisée, adaptée aux enjeux métiers et réglementaires. Le SI de l'hôpital supporte des fonctions critiques telles que la gestion des dossiers patients, la communication interne, la télémedecine et la supervision des équipements médicaux connectés. Toute interruption ou compromission de ces services est susceptible d'engager directement la sécurité des patients.

## 1.3 Objet de notre intervention

Notre mission s'articule autour de la refonte intégrale de l'architecture technique du SI de l'hôpital. Elle comprend les volets suivants :

- **Analyse de l'existant** : audit des équipements, identification des vulnérabilités et des risques associés à l'architecture actuelle.
- **Conception d'une nouvelle architecture sécurisée** : cloisonnement réseau, mise en place d'équipements de sécurité (pare-feu, IDS/IPS, SIEM), gestion des identités et des accès (Active Directory), et plans de continuité (PCA/PRA).
- **Définition de la politique de sécurité du SI (PSSI)** : axes techniques structurants alignés sur les référentiels ANSSI et les bonnes pratiques du secteur hospitalier.

- **Gestion de projet** : planification des travaux, matrice RACI, analyse des risques projet et jalons de validation.

Le présent Document d'Architecture Technique (DAT) constitue le livrable principal de notre intervention. Il formalise l'ensemble de nos analyses, choix techniques et recommandations, et servira de référence tout au long du projet de sécurisation du SI hospitalier.

## 2. Analyse de l'existant

### 2.1 Objectif de l'analyse

Dans le cadre de notre intervention, nous avons réalisé une analyse approfondie du système d'information de votre établissement. Cette étape préalable est indispensable : elle nous permet de dresser un état des lieux objectif et documenté, sur lequel s'appuiera l'ensemble de nos recommandations.

Cette analyse répond à quatre objectifs principaux : cartographier les composants techniques en place, évaluer le niveau de maturité en matière de cybersécurité, identifier les vulnérabilités existantes, et apprécier les risques susceptibles d'affecter la continuité des soins.

En tant qu'OIV, votre établissement est soumis à des exigences élevées en matière de résilience et de protection des données. Cette phase d'analyse constitue donc le socle de toute démarche de sécurisation sérieuse, et conditionne la pertinence des choix d'architecture qui seront proposés par la suite.

### 2.2 État des lieux du système d'information

L'analyse révèle une architecture typique des systèmes d'information historiques : construite progressivement, au fil des besoins opérationnels, sans intégration structurée des enjeux de cybersécurité.

Le système repose sur un réseau interne unique et non segmenté, au sein duquel cohabitent l'ensemble des équipements — postes utilisateurs, serveurs, équipements métiers. Cette architecture dite « à plat » ne permet pas d'isoler les usages entre eux, ni de contenir une éventuelle compromission.

| Composant        | Situation observée                               | Limites identifiées                                             |
|------------------|--------------------------------------------------|-----------------------------------------------------------------|
| Réseau           | Réseau interne unique, sans segmentation logique | Facilite les déplacements latéraux et la propagation d'attaques |
| Authentification | Comptes locaux ou Active Directory peu structuré | Gestion des accès non maîtrisée, traçabilité insuffisante       |

|                     |                                                |                                                                    |
|---------------------|------------------------------------------------|--------------------------------------------------------------------|
| Serveur de fichiers | Stockage centralisé avec droits d'accès larges | Exposition au risque de fuite ou d'altération de données sensibles |
| Pare-feu            | Filtrage minimal en périphérie uniquement      | Absence de contrôle des flux internes                              |
| Supervision         | Outils absents ou partiels                     | Incapacité à détecter rapidement un incident                       |
| Sauvegardes         | Non centralisées et non testées                | Capacité de reprise insuffisante en cas d'incident majeur          |

L'architecture actuelle ne répond pas aux exigences d'un environnement hospitalier critique. Elle présente un manque structurel de cloisonnement, de contrôle et de visibilité, ce qui élargit considérablement la surface d'attaque exposée.

## 2.3 Analyse des vulnérabilités

L'analyse technique met en évidence cinq vulnérabilités majeures, susceptibles d'être exploitées dans le cadre d'une attaque ciblée.

**Absence de segmentation réseau** L'ensemble des équipements peut communiquer librement, sans restriction ni cloisonnement. En l'absence de mécanisme de confinement, la compromission d'un seul poste utilisateur peut se propager rapidement à l'ensemble du système d'information, y compris aux serveurs les plus critiques.

**Insuffisance de la gestion des identités et des accès** Il n'existe pas de politique de mot de passe robuste. Les comptes à privilèges élevés ne sont pas isolés et les droits ne font l'objet d'aucune révision régulière. Cette situation facilite la compromission de comptes administrateurs et la prise de contrôle du système.

**Exposition des données patients** Les données de santé ne bénéficient ni de chiffrement, ni d'un contrôle d'accès adapté à leur sensibilité. La journalisation est insuffisante pour assurer la traçabilité des accès. Ce constat expose l'établissement à des risques de fuite de données, avec des conséquences réglementaires (RGPD) et réputationnelles potentiellement significatives.

**Absence de capacité de détection** Le système d'information ne dispose d'aucun mécanisme centralisé de surveillance (SIEM, corrélation de logs). Un incident de sécurité peut ainsi rester non détecté pendant une période prolongée, ce qui en aggrave considérablement les conséquences.

**Insuffisance des dispositifs de continuité d'activité** Les sauvegardes en place n'ont pas fait l'objet de tests de restauration, et aucun Plan de Reprise d'Activité formalisé n'existe à ce jour. En cas d'incident majeur — une attaque par ransomware, par exemple — la reprise des activités critiques dans des délais acceptables ne pourrait pas être garantie.

## 2.4 Synthèse des risques

L'ensemble de ces vulnérabilités expose le système d'information à des risques majeurs, incompatibles avec les exigences d'un établissement de santé.

| Risque                | Impact potentiel                                  | Probabilité | Criticité |
|-----------------------|---------------------------------------------------|-------------|-----------|
| Ransomware            | Interruption des soins, perte de données patients | Élevée      | Critique  |
| Fuite de données      | Sanctions RGPD, atteinte à la réputation          | Moyenne     | Critique  |
| Indisponibilité du SI | Blocage des activités médicales                   | Moyenne     | Critique  |
| Intrusion réseau      | Compromission globale du système d'information    | Élevée      | Critique  |

## 3. Architecture cible proposée

### 3.1 Objectifs de l'architecture

Les vulnérabilités identifiées lors de l'analyse de l'existant appellent une refonte structurée du système d'information. L'architecture cible que nous proposons a été conçue pour répondre aux exigences spécifiques d'un établissement hospitalier classé Opérateur d'Importance Vitale, en s'articulant autour de quatre axes structurants.

**Cloisonnement du système d'information** La rupture avec l'architecture réseau plate constitue le premier chantier de cette transformation. Nous proposons une segmentation logique du SI en zones distinctes et étanches — administration, médical, supervision, sauvegarde — dont les communications sont strictement contrôlées par le pare-feu central. Cette approche s'inscrit dans une logique Zero Trust : aucun flux n'est considéré comme légitime par défaut, y compris au sein du réseau interne. En cas de compromission, cette organisation permet de contenir l'incident et d'éviter toute propagation latérale.

**Sécurisation des accès** La gestion des identités est centralisée au sein d'un annuaire Active Directory, qui constitue le socle de la politique d'accès. Les droits sont attribués selon un modèle RBAC (Role-Based Access Control) : chaque utilisateur dispose uniquement des privilèges nécessaires à l'exercice de ses fonctions. Des politiques de sécurité (GPO) complètent ce dispositif pour renforcer la posture des postes de travail et garantir une traçabilité des accès aux ressources sensibles.

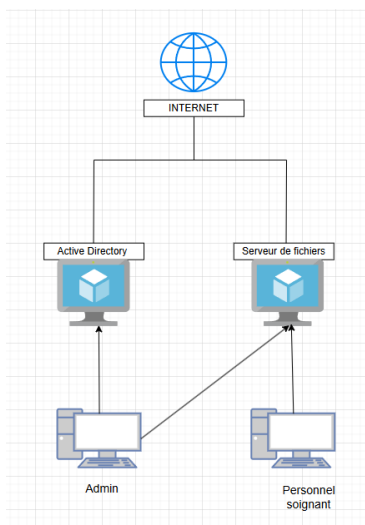
**Supervision et détection en temps réel** L'architecture intègre deux niveaux de surveillance complémentaires : un monitoring technique pour le suivi de l'état des équipements, et un SIEM pour la collecte, la corrélation et l'analyse des événements de

sécurité. Cette visibilité accrue permet de détecter rapidement tout comportement anormal et d'enclencher une réponse proactive avant qu'un incident ne s'aggrave.

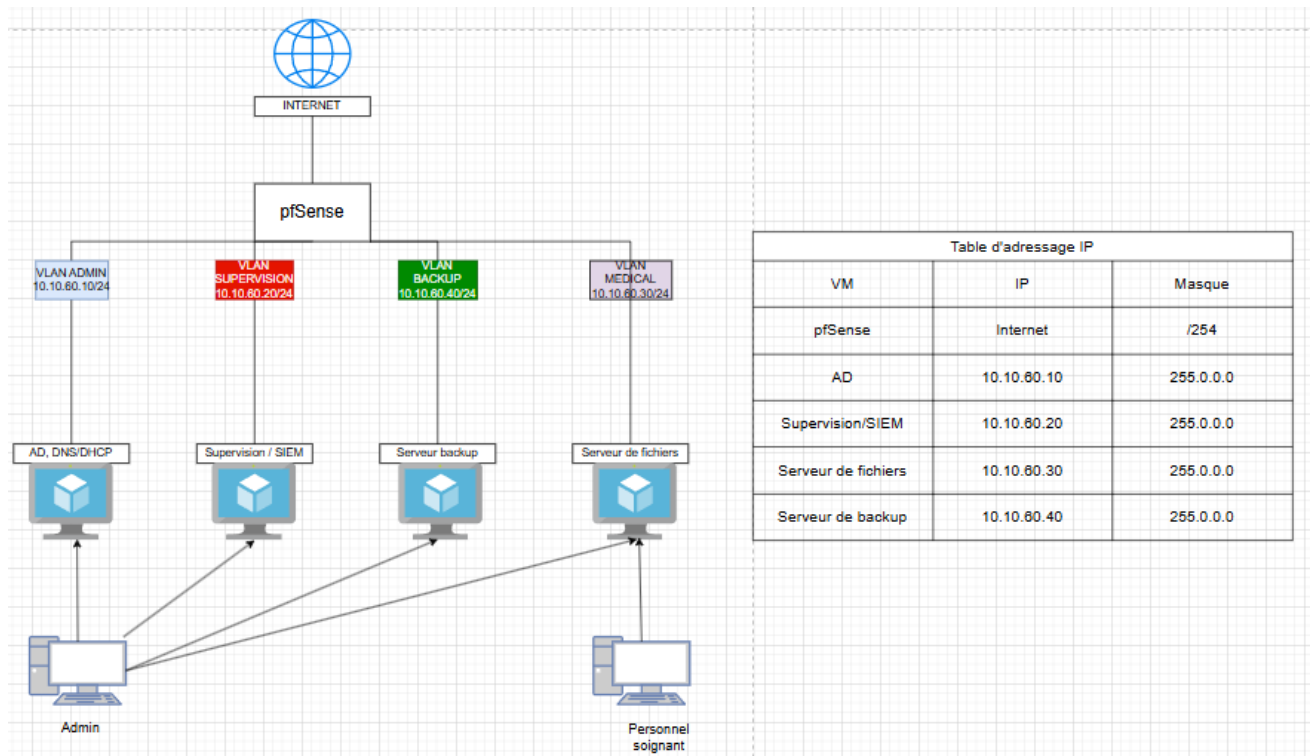
**Continuité d'activité** La disponibilité du système d'information conditionne directement la continuité des soins. L'architecture prévoit en conséquence une stratégie de sauvegarde fiable, régulière et isolée du reste du SI, ainsi que la formalisation d'un Plan de Reprise d'Activité testé et opérationnel. Ces mécanismes permettent de garantir une restauration rapide des services critiques en cas d'incident majeur, notamment face à une attaque par ransomware.

## 3.2 Schéma AVANT / APRÈS

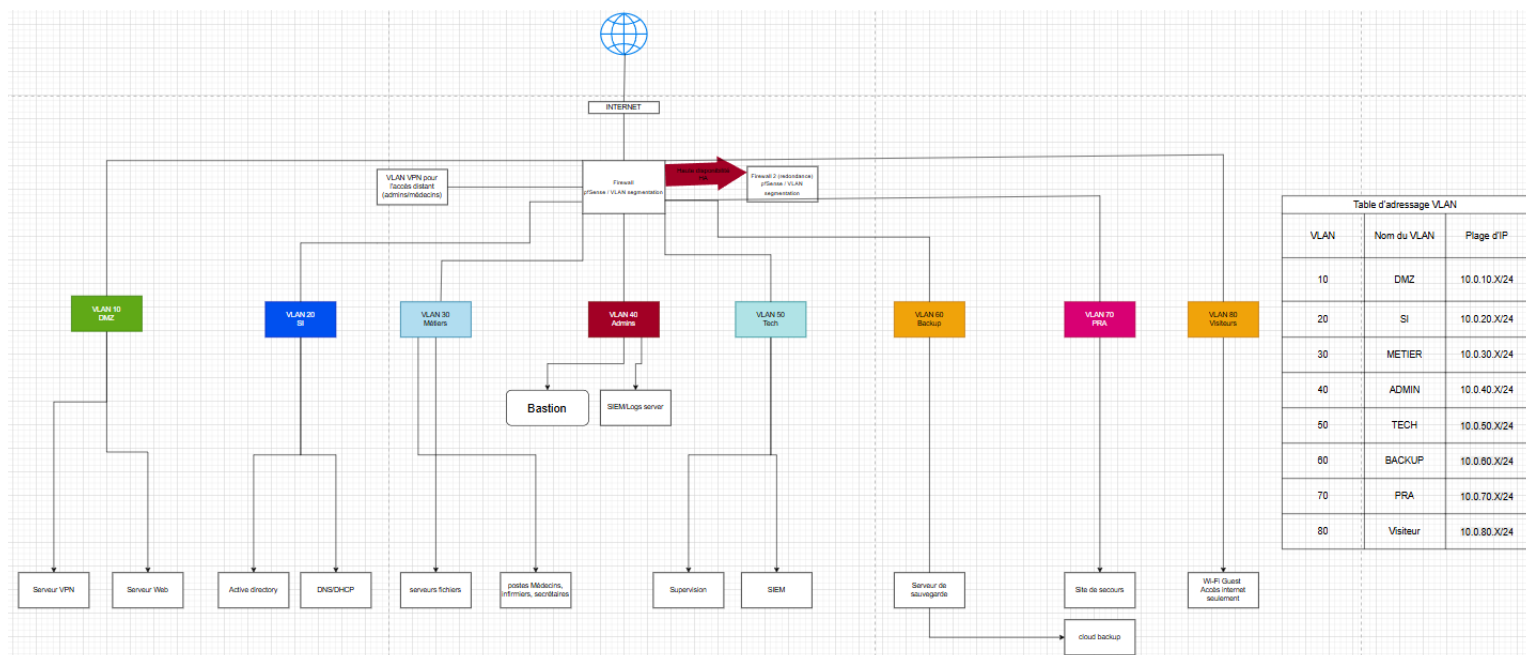
**L'architecture actuelle :**



Après :



(Architecture théorique)



### 3.3 Description de l'architecture cible

L'architecture proposée s'appuie sur plusieurs briques techniques complémentaires, organisées de manière cohérente pour couvrir l'ensemble des enjeux de sécurité identifiés.

**Pare-feu central** Le pare-feu constitue la colonne vertébrale du dispositif de sécurité réseau. Il assure le filtrage de l'ensemble des flux entre les zones du SI, la mise en œuvre de la segmentation logique, ainsi que la gestion des accès distants via VPN sécurisé. La politique de filtrage appliquée repose sur le principe du moindre privilège réseau : tout ce qui n'est pas explicitement autorisé est bloqué par défaut.

**Gestion des identités et des accès** L'Active Directory centralise la gestion des comptes utilisateurs et l'application des politiques de sécurité. Il permet une administration homogène des droits, une mise en œuvre rigoureuse du contrôle d'accès basé sur les rôles, et une traçabilité des actions réalisées sur le système d'information.

**Supervision et détection des incidents** La double couche de supervision combine un outil de monitoring opérationnel — pour surveiller la disponibilité et les performances des équipements — et un SIEM dédié à la collecte et à l'analyse des logs de sécurité. Cette combinaison assure une couverture complète, aussi bien sur le plan opérationnel que sur le plan de la détection des menaces.

**Infrastructure de sauvegarde et Plan de Reprise d'Activité** Les sauvegardes sont réalisées de manière régulière, chiffrées, et stockées dans une zone isolée du reste du SI afin de les préserver en cas de compromission. Le Plan de Reprise d'Activité associé est formalisé et fait l'objet de tests périodiques, garantissant ainsi la capacité de l'établissement à restaurer ses services critiques dans des délais maîtrisés.

## 4. Choix techniques et benchmarking

Dans un contexte de contraintes budgétaires significatives, notre sélection s'est orientée vers des solutions open source reconnues, offrant un niveau de sécurité et de performance adapté à l'environnement, pour un coût de licence nul.

### 4.1 Pare-feu

| Solution         | Avantages                                                            | Inconvénients                                        | Retenu |
|------------------|----------------------------------------------------------------------|------------------------------------------------------|--------|
| <b>pfSense</b>   | Open source, riche fonctionnellement, support VPN, communauté active | Nécessite une expertise technique à la prise en main | Oui    |
| <b>FortiGate</b> | Solution performante et intégrée, support professionnel              | Coût d'acquisition et de maintenance élevé           | Non    |

**Justification** : pfSense offre un niveau fonctionnel adapté aux besoins de l'établissement, sans coût de licence. Sa communauté active et la richesse de sa documentation en font une solution viable et pérenne dans un contexte budgétaire contraint.

## 4.2 Supervision

| Solution      | Avantages                                                         | Inconvénients                                        | Retenu |
|---------------|-------------------------------------------------------------------|------------------------------------------------------|--------|
| <b>Zabbix</b> | Open source, interface web moderne, monitoring avancé et flexible | Courbe d'apprentissage initiale                      | Oui    |
| <b>Nagios</b> | Solution historique, stable et éprouvée                           | Interface vieillissante, configuration plus complexe | Non    |

**Justification :** Zabbix a été retenu pour sa capacité à fournir une supervision détaillée et granulaire de l'infrastructure, ainsi que pour la qualité de son interface d'administration.

## 4.3 SIEM

| Solution      | Avantages                                                        | Inconvénients                                    | Retenu |
|---------------|------------------------------------------------------------------|--------------------------------------------------|--------|
| <b>Wazuh</b>  | Open source, intégration EDR native, bonne capacité de détection | Consommation de ressources à anticiper           | Oui    |
| <b>Splunk</b> | Très performant, fonctionnalités avancées                        | Coût prohibitif, inadapté au contexte budgétaire | Non    |

**Justification :** Wazuh permet de mettre en œuvre un dispositif de détection efficace et de simuler les fonctions d'un SOC, tout en s'inscrivant dans les contraintes budgétaires du projet.

## 4.4 Serveur de fichiers

| Solution              | Avantages                                                  | Inconvénients                         | Retenu |
|-----------------------|------------------------------------------------------------|---------------------------------------|--------|
| <b>Samba</b>          | Open source, interopérable avec Active Directory, flexible | Configuration initiale plus technique | Oui    |
| <b>Windows Server</b> | Intégration native avec AD, administration simplifiée      | Coût de licence significatif          | Non    |

**Justification :** Samba constitue une solution performante et économique, pleinement compatible avec l'écosystème Active Directory retenu pour la gestion des identités.

## 4.5 Solution de sauvegarde

Solution de sauvegarde – Dans un contexte de sécurisation des données critiques de l'établissement hospitalier, la solution retenue doit garantir à la fois la confidentialité,

l'intégrité et la disponibilité des sauvegardes, tout en restant compatible avec une infrastructure virtualisée (Proxmox, AD, serveurs de fichiers).

| Solution          | Avantages                                                                                               | Inconvénients                                                               | Retenu |
|-------------------|---------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|--------|
| <b>Restic</b>     | Open source, chiffrement natif (AES-256), simplicité d'utilisation, sauvegardes incrémentales efficaces | Interface en ligne de commande uniquement                                   | Oui    |
| <b>BorgBackup</b> | Déduplication avancée, chiffrement natif, très performant sur les volumes importants                    | Prise en main plus complexe, moins orienté administration simple            | Non    |
| <b>UrBackup</b>   | Interface web, gestion centralisée, sauvegarde de postes et d'images système                            | Moins adapté aux environnements purement serveurs, architecture plus lourde | Non    |
| <b>Duplicati</b>  | Interface web simple, sauvegarde de fichiers facile à configurer                                        | Moins robuste pour environnements critiques, performances variables         | Non    |
| <b>Bareos</b>     | Solution complète type entreprise, gestion avancée des politiques de sauvegarde                         | Complexité élevée, surdimensionné pour le périmètre du projet               | Non    |

#### Justification :

Restic a été retenu pour sa simplicité de mise en œuvre, sa légèreté et surtout son chiffrement natif des sauvegardes, garantissant la confidentialité des données sensibles de santé. Il s'intègre facilement dans une infrastructure virtualisée sans nécessiter d'architecture lourde de type client-serveur. Son fonctionnement incrémental permet également d'optimiser l'espace de stockage et les performances.

## 4.6 IDS/IPS

| Solution | Avantages                                                                                          | Inconvénients                          | Retenu |
|----------|----------------------------------------------------------------------------------------------------|----------------------------------------|--------|
| Suricata | Open source, intégration native avec pfSense, support IDS/IPS, règles ET Open, bonnes performances | Configuration et tuning plus complexes | Oui    |

|       |                                                                |                                                                |     |
|-------|----------------------------------------------------------------|----------------------------------------------------------------|-----|
| Snort | Solution historique et très utilisée, large base de signatures | Certaines règles avancées payantes, intégration moins flexible | Non |
|-------|----------------------------------------------------------------|----------------------------------------------------------------|-----|

Suricata a été retenu pour son intégration native avec pfSense, son fonctionnement en IDS/IPS et sa compatibilité avec les règles ET Open, permettant une surveillance efficace du trafic réseau et une meilleure intégration avec le SIEM Wazuh.

## 5. Politique de sécurité technique

### 5.1 Principes appliqués

L'architecture cible a été conçue en cohérence directe avec la Politique de Sécurité des Systèmes d'Information de l'établissement. Les principes fondamentaux qui la structurent ne sont pas de simples orientations théoriques : ils se traduisent par des choix techniques concrets.

#### **Confidentialité, intégrité et disponibilité**

Ces trois piliers fondamentaux de la sécurité des systèmes d'information se déclinent comme suit dans l'architecture proposée. La confidentialité est assurée par un contrôle strict des accès aux données de santé, reposant sur Active Directory et le modèle RBAC. L'intégrité est garantie par la journalisation centralisée de l'ensemble des modifications, corrélée et analysée via le SIEM. La disponibilité s'appuie sur la stratégie de sauvegarde mise en œuvre avec Restic et sur le Plan de Reprise d'Activité formalisé.

#### **Principes structurants de l'architecture**

*Zero Trust* — Aucun flux réseau n'est considéré comme fiable par défaut, y compris au sein du réseau interne. Chaque communication est authentifiée, filtrée et journalisée via pfSense.

*Moindre privilège* — Chaque utilisateur et chaque service dispose uniquement des droits strictement nécessaires à l'exercice de ses fonctions. Ce principe est appliqué par la structuration de l'Active Directory en unités organisationnelles, groupes et GPO dédiés.

*Deny by default* — L'ensemble des communications réseau est bloqué par défaut au niveau du pare-feu. Seuls les flux explicitement identifiés et autorisés peuvent transiter.

*Segmentation réseau* — Le système d'information est organisé en zones logiques distinctes — ADMIN, MEDICAL, SUPERVISION, BACKUP — isolées par filtrage pfSense, afin de limiter toute propagation en cas d'incident.

## 5.2 Mesures techniques de sécurité

Les mesures détaillées ci-dessous découlent directement des exigences de la PSSI et sont implémentées dans l'architecture cible.

### **Contrôle des flux réseau**

Le filtrage est assuré de manière stricte par pfSense. Les communications directes non nécessaires entre zones sont bloquées — notamment entre les zones MEDICAL et BACKUP. L'ensemble des flux, qu'ils soient autorisés ou refusés, est systématiquement journalisé et transmis au SIEM.

### **Durcissement des protocoles réseau**

Les protocoles obsolètes ou présentant des vulnérabilités connues sont désactivés : SMBv1 et LLMNR ne sont plus opérationnels dans l'environnement cible. Les partages de fichiers s'appuient exclusivement sur SMB 3.0 en mode chiffré. Les protocoles non sécurisés — FTP, Telnet — sont interdits sur l'ensemble du périmètre.

### **Gestion des accès et authentification**

L'authentification est centralisée via Active Directory, ce qui permet la suppression des comptes locaux non maîtrisés. La séparation des privilèges est organisée selon un modèle de tiering à trois niveaux (Tier 0 / Tier 1 / Tier 2). La politique de mots de passe, appliquée par GPO, impose une complexité obligatoire, une rotation régulière et un verrouillage automatique des comptes après plusieurs tentatives d'authentification infructueuses.

### **Accès distant sécurisé**

L'accès au système d'information depuis l'extérieur est exclusivement conditionné au passage par un VPN OpenVPN, déployé sur pfSense. Une authentification à double facteur est exigée, combinant les credentials Active Directory et un certificat. Le split tunneling est désactivé afin de garantir que l'ensemble du trafic transite par le périmètre de sécurité. Les accès VPN sont restreints à des groupes Active Directory spécifiques, et l'ensemble des sessions distantes est intégralement journalisé.

### **Supervision et traçabilité**

Les logs de l'ensemble des composants sont centralisés sur le SIEM Wazuh. La surveillance porte en priorité sur les événements à fort enjeu : authentifications Active Directory, accès aux fichiers sensibles et activité des règles de filtrage pfSense. Des règles de détection d'anomalies sont configurées pour identifier les comportements suspects — tentatives de brute force, exfiltration de données, accès non autorisés.

### **Protection des données**

Les données au repos sont chiffrées en AES-256. Les communications sont protégées par TLS 1.2 minimum et SSH v2. L'accès aux dossiers patients fait l'objet d'un contrôle strict, et chaque accès aux données médicales est tracé et journalisé.

### Continuité et résilience

Les sauvegardes sont automatisées via Restic et organisées selon la règle 3-2-1 : trois copies des données, sur deux supports différents, dont une copie isolée dans la zone BACKUP. Les sauvegardes sont chiffrées. Des tests de restauration sont réalisés régulièrement dans l'environnement virtuel afin de vérifier l'effectivité du dispositif.

## 5.3 Synthèse opérationnelle

L'ensemble des mesures techniques décrites dans cette section permet de répondre de manière cohérente et documentée aux objectifs fixés par la PSSI de l'établissement. Elles contribuent à réduire la surface d'attaque exposée, à limiter la propagation latérale en cas de compromission, à détecter rapidement tout incident de sécurité, à renforcer la protection des données de santé et à garantir la capacité de reprise d'activité en cas de sinistre.

Cette approche assure par ailleurs une cohérence entre les exigences réglementaires auxquelles l'établissement est soumis — RGPD, directive NIS2, référentiel HDS — et leur traduction technique effective dans l'architecture virtualisée déployée.

## 6. Partie technique

### 6.1. Matrice de flux

Une matrice de flux a également été mise en place afin de contrôler les communications entre les différentes VMs du réseau et limiter les échanges aux services strictement nécessaires :

| Source  | IP source     | Destination | IP destination | Service                | Port(s) | Protocole | Action | Justification                                        |
|---------|---------------|-------------|----------------|------------------------|---------|-----------|--------|------------------------------------------------------|
| LAN net | 10.10.60.0/24 | LAN net     | 10.10.60.0/24  | Communication inter-VM | Any     | Any       | Pass   | Permettre les échanges internes entre les VMs du lab |

|         |               |      |             |               |      |         |      |                                                       |
|---------|---------------|------|-------------|---------------|------|---------|------|-------------------------------------------------------|
| LAN net | 10.10.60.0/24 | WAN  | any         | DNS           | 53   | TCP/UDP | Pass | Autoriser la résolution DNS                           |
| LAN net | 10.10.60.0/24 | WAN  | any         | HTTP          | 80   | TCP     | Pass | Autoriser les mises à jour et accès web non sécurisés |
| LAN net | 10.10.60.0/24 | WAN  | any         | HTTPS         | 443  | TCP     | Pass | Autoriser les accès web sécurisés                     |
| LAN net | 10.10.60.0/24 | WAN  | any         | Ping Internet | ICMP | ICMP    | Pass | Vérification de connectivité réseau                   |
| LAN net | 10.10.60.0/24 | AD   | 10.10.60.10 | LDAP          | 389  | TCP     | Pass | Authentification et annuaire Active Directory         |
| LAN net | 10.10.60.0/24 | AD   | 10.10.60.10 | LDAPS         | 636  | TCP     | Pass | LDAP sécurisé pour Active Directory                   |
| LAN net | 10.10.60.0/24 | AD   | 10.10.60.10 | Kerberos      | 88   | TCP     | Pass | Authentification des utilisateurs du domaine          |
| LAN net | 10.10.60.0/24 | AD   | 10.10.60.10 | DNS AD        | 53   | TCP/UDP | Pass | Résolution DNS du domaine Active Directory            |
| LAN net | 10.10.60.0/24 | AD   | 10.10.60.10 | RPC           | 135  | TCP     | Pass | Communication des services Active Directory           |
| LAN net | 10.10.60.0/24 | SIEM | 10.10.60.20 | Wazuh agents  | 1514 | TCP     | Pass | Envoi des logs sécurité vers Wazuh                    |

|             |               |             |               |                          |         |         |       |                                                                                 |
|-------------|---------------|-------------|---------------|--------------------------|---------|---------|-------|---------------------------------------------------------------------------------|
| LAN net     | 10.10.60.0/24 | SIEM        | 10.10.60.20   | Wazuh enrollment         | 1515    | TCP     | Pass  | Enrôlement des agents Wazuh                                                     |
| LAN net     | 10.10.60.0/24 | SIEM        | 10.10.60.20   | Zabbix Agent             | 10050   | TCP     | Pass  | Remontée des métriques système                                                  |
| SIEM        | 10.10.60.20   | LAN net     | 10.10.60.0/24 | Zabbix Server            | 10051   | TCP     | Pass  | Supervision active des machines du réseau                                       |
| LAN net     | 10.10.60.0/24 | File Server | 10.10.60.30   | SMB                      | 445     | TCP     | Pass  | Accès aux partages de fichiers                                                  |
| LAN net     | 10.10.60.0/24 | File Server | 10.10.60.30   | NetBIOS                  | 137-139 | TCP/UDP | Pass  | Compatibilité anciens services Windows                                          |
| File Server | 10.10.60.30   | AD          | 10.10.60.10   | LDAP/Kerberos            | 389/88  | TCP     | Pass  | Authentification du serveur de fichiers sur le domaine AD                       |
| Backup      | 10.10.60.40   | SIEM        | 10.10.60.20   | Sauvegarde Restic SSH    | 22      | TCP     | Pass  | Sauvegarde distante de la VM SIEM via SSH                                       |
| Backup      | 10.10.60.40   | AD          | 10.10.60.10   | Sauvegarde Restic SSH    | 22      | TCP     | Pass  | Sauvegarde distante de la VM AD via SSH                                         |
| Backup      | 10.10.60.40   | File Server | 10.10.60.30   | Sauvegarde Restic SSH    | 22      | TCP     | Pass  | Sauvegarde distante du serveur de fichiers                                      |
| Any         | any           | Any         | any           | Tout trafic non autorisé | Any     | Any     | Block | Politique de sécurité par défaut : blocage du trafic non explicitement autorisé |

## 6.2. IDS/IPS

L'IDS/IPS Suricata a été déployé sur pfSense afin de surveiller le trafic réseau et détecter les activités suspectes.

Configuration :

- Interface surveillée : LAN (10.10.60.0/24)
- Ruleset : ET Open
- Catégories activées :
  - attack\_response
  - botcc
  - current\_events
  - exploit
  - malware
  - scan

Objectifs :

- Détection des scans réseau
- Détection des comportements malveillants
- Surveillance du trafic interne
- Génération d'alertes de sécurité

## 6.3 Proxy / Filtrage web — SquidGuard

SquidGuard a été déployé sur pfSense afin de mettre en place un filtrage des accès web et renforcer la sécurité de la navigation Internet.

Objectifs

- Contrôle des accès Internet
- Blocage des sites non autorisés
- Filtrage des catégories de contenus
- Renforcement de la sécurité réseau

Intégration

SquidGuard fonctionne en complément du proxy Squid et du firewall pfSense pour contrôler le trafic web sortant.

## 7. RACI

Dans le cadre de la mise en œuvre de la nouvelle architecture du SI, une matrice RACI a été définie afin de clarifier les rôles et responsabilités des différents acteurs du projet.

Cette matrice permet d'assurer une gouvernance cohérente entre les phases de conception, de déploiement, de validation et d'exploitation de l'infrastructure.

Elle contribue également à garantir une répartition claire des responsabilités entre les équipes techniques, les instances de sécurité et les parties prenantes métiers, conformément aux bonnes pratiques de gestion de projet et de gouvernance des systèmes d'information.

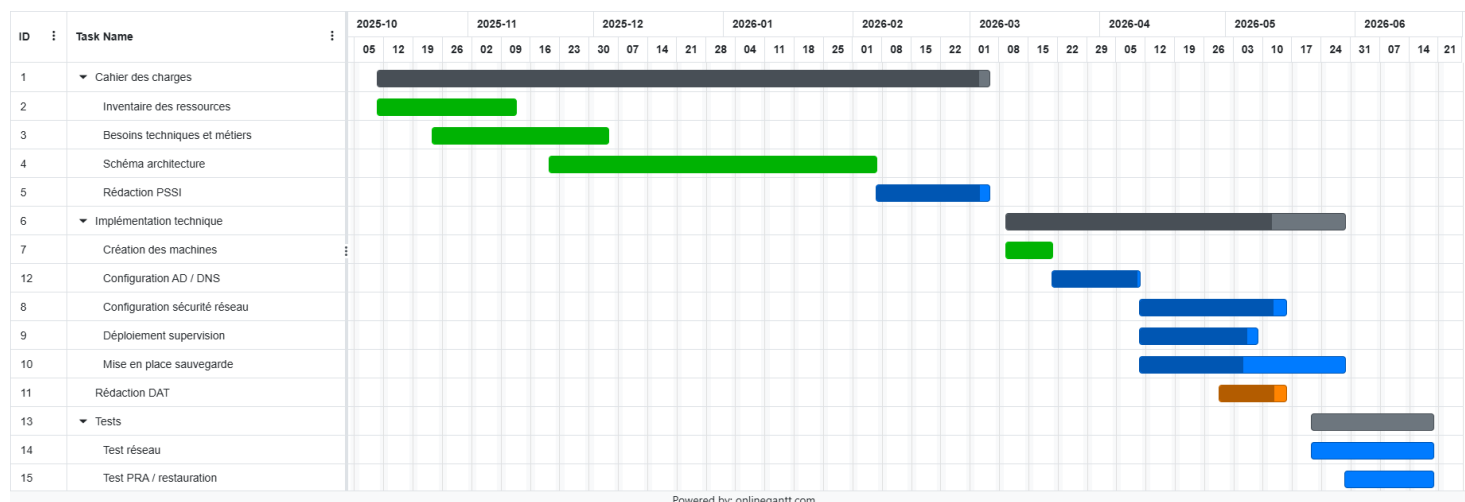
*R = Réalisateur · A = Approbateur · C = Consulté · I = Informé*

| Activité                                      | Direction Général | RSSI | Équipe IT | Prestataires | Utilisateurs | DPO |
|-----------------------------------------------|-------------------|------|-----------|--------------|--------------|-----|
| Conception architecture cible                 | I                 | A    | C         | R            | I            | I   |
| Choix des solutions techniques                | I                 | A    | C         | R            | I            | I   |
| Mise en place infrastructure (VM, réseau, AD) | I                 | C    | R         | R            | I            | I   |
| Configuration sécurité (pfSense, SIEM, GPO)   | I                 | A    | R         | R            | I            | I   |
| Déploiement supervision (Zabbix, Wazuh)       | I                 | A    | R         | R            | I            | I   |
| Mise en place sauvegardes (Restic)            | I                 | A    | R         | R            | I            | I   |
| Rédaction PSSI                                | A                 | R    | C         | R            | I            | C   |
| Tests PRA / restauration                      | I                 | A    | R         | R            | I            | I   |
| Validation des choix techniques               | A                 | R    | C         | C            | I            | I   |
| Formation / sensibilisation                   | I                 | A    | C         | R            | R            | C   |
| Exploitation quotidienne                      | I                 | A    | R         | I            | R            | I   |

## 8. Planning

Le projet a été conduit selon une approche progressive, permettant de structurer les différentes phases entre analyse des besoins, conception de l'architecture, implémentation technique et production documentaire.

Le planning ci-dessous présente l'avancement des principales tâches réalisées dans le cadre du projet de sécurisation du système d'information :



### Synthèse de l'avancement :

À la date de rédaction de ce document, les phases d'analyse, de conception et de déploiement de l'infrastructure principale sont majoritairement finalisées. Les travaux restants concernent principalement :

- La finalisation des règles de sécurité et du filtrage inter-zones ;
- L'achèvement de la stratégie de sauvegarde et des tests de restauration ;
- La finalisation de la configuration de l'Active directory ;
- Les tests de filtrages réseau et PRA/restauration ;

L'avancement global du projet est estimé à un niveau satisfaisant au regard du planning initial et des objectifs fixés dans le cahier des charges.

## 9. Conclusion

Le présent Document d'Architecture Technique formalise l'ensemble des travaux réalisés dans le cadre de la sécurisation du système d'information de l'établissement hospitalier. L'analyse de l'existant a mis en évidence plusieurs vulnérabilités critiques

incompatibles avec les exigences de sécurité attendues pour un environnement de santé classé Opérateur d'Importance Vitale, notamment en matière de cloisonnement réseau, de supervision, de gestion des accès et de continuité d'activité.

Afin de répondre à ces enjeux, nous avons conçu une architecture cible reposant sur une approche de défense en profondeur, intégrant segmentation réseau, contrôle strict des flux, centralisation des identités, supervision temps réel et stratégie de sauvegarde sécurisée. Les solutions retenues ont été sélectionnées à l'issue d'un benchmarking technique prenant en compte les contraintes budgétaires du projet, tout en garantissant un niveau de sécurité cohérent avec les recommandations de l'ANSSI, les exigences du RGPD, de NIS2 et du référentiel HDS.

L'infrastructure virtualisée mise en œuvre permet aujourd'hui :

- De réduire significativement la surface d'attaque exposée ;
- De limiter les risques de propagation latérale en cas de compromission ;
- D'améliorer la capacité de détection et de réaction face aux incidents ;
- De renforcer la protection des données de santé ;
- De garantir une meilleure résilience du système d'information grâce aux mécanismes de sauvegarde et de reprise d'activité.

Les travaux restant à finaliser concernent principalement les phases de validation opérationnelle, les derniers ajustements de sécurité, ainsi que les tests complets de restauration et de PRA. Ces éléments permettront de consolider l'architecture et de confirmer son adéquation avec les objectifs de sécurité fixés par l'établissement.

Enfin, ce DAT constitue une base de référence technique pour l'exploitation future du système d'information. Il pourra servir de support aux évolutions ultérieures de l'infrastructure, aux audits de conformité et aux démarches d'amélioration continue de la cybersécurité au sein de l'hôpital.